title: Token replay in Microsoft 365: why a strong password and MFA are not enough on their own
date: 2026-10-28
summary: A reported campaign used an adversary-in-the-middle relay to capture sign-in sessions. What it means for your sign-in controls, and the checks to run this week.
draft: false

What was reported

- **Campaign.** The Hacker News reported on 26 Oct 2026 that a Microsoft 365 campaign used an adversary-in-the-middle (AitM) relay to capture sign-in sessions and was linked to 97 compromised accounts at 79 organisations. The full victim list is not public.
- **Mechanism.** An AitM relay sits between the user and the real sign-in page. The user completes the password and MFA prompt, and the attacker keeps the resulting session token. Replaying that token can work without the password or a new MFA prompt.

Confirmed (from the report): the campaign, its reported scale, and the AitM technique.
Likely: the same technique will be used again against organisations that rely only on password plus push or code MFA.
Unclear: the exact phishing kit, the initial lure, and whether your tenant was targeted. Do not treat these as known.

Why this matters for your tenant

Password and MFA checks happen at sign-in. A stolen session token skips them until it expires or is revoked. That changes the priorities:

1. **Phishing-resistant MFA** (FIDO2 security keys or passkeys) makes the relay useless for the protected accounts, because the login is bound to the real site.
2. **Session lifetime and revocation** limit the damage window. Know how to revoke sessions for a user quickly.
3. **Sign-in risk and anomalies** are the detection layer. Token replay often shows as a session used from an unexpected network, device or client.

What I would check this week

1. **Sign-in logs (Entra ID):** filter for interactive sign-ins with unusual user agents, new countries or new devices for admin and finance accounts. Note: no single entry proves compromise.
2. **Admin accounts first:** confirm they use phishing-resistant MFA. If not, plan that before anything else.
3. **Conditional Access:** review sign-in frequency and any policies on sensitive apps. Check the current Microsoft documentation for token protection and its requirements before you plan it, because capabilities and licence needs change.
4. **Revocation runbook:** test it once on a test account. Write down who can run it and how long it takes.
5. **Users:** a short note explaining that a login prompt that appears unexpected should be reported, not approved.

Verification

- Admin accounts show a phishing-resistant method in the authentication methods report.
- A revocation test on a test account removes access as expected.
- Sign-in log review for the last 14 days is recorded, including the result for each account reviewed.

Source for the campaign: The Hacker News, 26 Oct 2026, as summarised on this site. Check the original report before sharing these figures.